

# OSGUARDIAN ANTI-MALWARE DESIGN

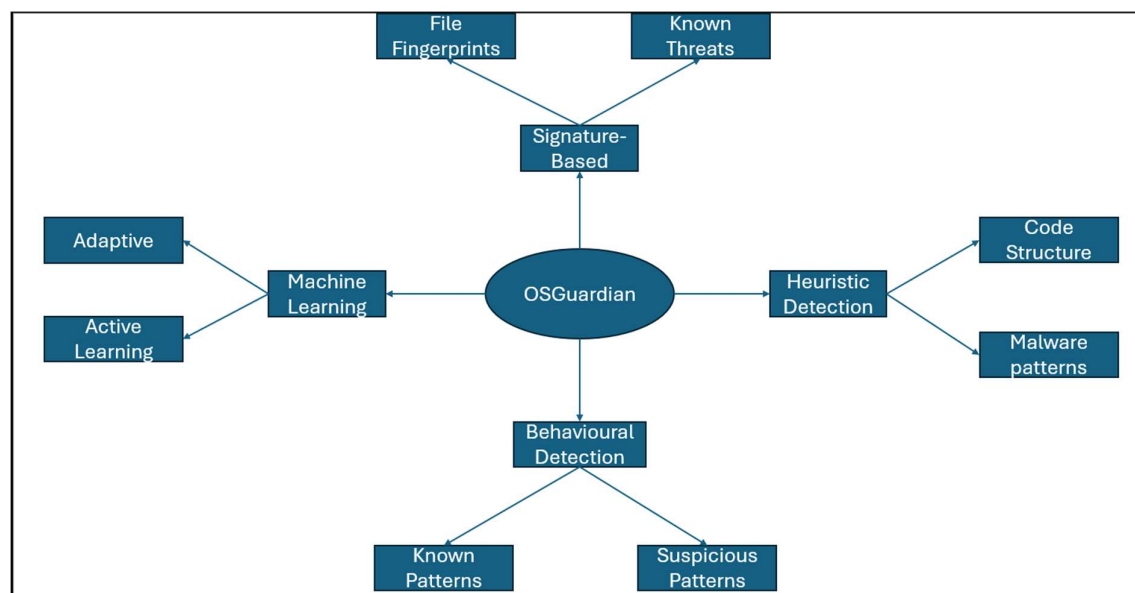
## Contents

- Introduction ..... 2**
- OSGuardian’s Detection Layers..... 3**
- OSGuardian Scan Modes ..... 4**
- Ransomware-Specific Protections ..... 5**
- OSGuardian User Control, Privacy and Phishing Protections ..... 6**
- OSGuardian’s Workflow ..... 7**
- OSGuardian’s Update System and ML Handling ..... 8**
- OSGuardian’s Trade-offs ..... 9**

## Introduction

OSGuardian is designed to protect devices against multiple types of malware such as ransomware, RATs and worms. This is also designed to provide users with a privacy-first and human-centric approach to security. OSGuardian was developed not as a direct replacement to current AVs but as a model for improvement. This is because while current AVs are powerful, they are weak in a few areas such as privacy and coverage. This OSGuardian design will explain the different security and privacy features, the user workflow and the trade-offs.

OSGuardian cannot promise perfect protection or privacy during usage. However, it can provide multiple layers of protection and detection against malware rising the cost of successful compromise significantly. It can also provide multiple features for privacy and user-control while also be compatible with the operating system. For those who may want to implement OSGuardian, you will require OS development teams, security teams, maintainers and infrastructure. Make sure to adapt OSGuardian to specific security needs of the system it is protecting.



The Spider diagram above shows the 4 detection layers of OSGuardian and the two features of each detection layer. This spider diagram does not show every single feature of OSGuardian. More details for each detection layer can be found in the section below.

## **OSGuardian's Detection Layers**

- **OSGuardian has 4 detection layers for locating malware on a device**
- **The first layer is signature-based detection.**
- **Signature-based detection is where OSGuardian compares known signatures of malware to signatures of programs running on the device.**
- **Signature-based detection is mainly effective against pre-existing malware commonly used by script kiddies and opportunistic attackers.**
- **However, Signature-based detection fails when it comes to unknown malware-level threats as their signatures are not in the database yet.**
- **The second layer is heuristic detection.**
- **Heuristic detection is where OSGuardian analyses the code structure and behaviour of programs as malicious programs are structured and behave differently compared to legitimate software.**
- **Heuristic detection is mainly effective against unknown malware-level threats as it doesn't require the threat to be known to be detected by OSGuardian.**
- **However, heuristic detection fails when the malicious program behaves and uses code structures nearly identical to legitimate software.**
- **This catches unknown threats which signature-based detection may fail against.**
- **The third layer is behavioural detection.**
- **Behavioural detection is where OSGuardian monitors system activity in real-time for suspicious activities.**
- **These suspicious activities can include anomalous, bulk encryption patterns and programs accessing permissions or files they normally wouldn't do.**
- **Behavioural detection is mainly effective against unknown malicious programs hiding as legitimate software as it works in real-time and doesn't rely on code structure which can be faked.**
- **However, behavioural detection fails when malicious programs are nearly identical to legitimate software and maintain legitimate behaviour while on the device.**
- **The fourth layer is machine learning**
- **Machine learning is where OSGuardian learns from user-specific patterns, global threat data and real-malware threats to detect suspicious patterns.**
- **This can include learning the user-specific baseline during idle and what legitimate software and behavioural can appear like for the user.**
- **Machine learning is mainly effective against false positives and trojans as it can cross-reference user-specific patterns against malicious patterns.**
- **However, machine learning fails if the malware is specifically adapted or made to maintain user-specific behaviour which is highly unlikely to occur but possible.**
- **It then can adapt the AV over time to get better at detecting threats and avoiding more false positives.**
- **Together, these 4 layers can handle 90% of malware-level threats and raise the cost significantly for successful malware compromise on a device.**

## **OSGuardian Scan Modes**

- The user can choose 4 scan modes within OSGuardian's AV dashboard
- The first scan mode is Quick Scan
- Quick Scan is where OSGuardian quickly scans through the essential processes, protected folders and where malware is commonly found on a device.
- Quick scan is mainly effective against known malware-level threats as it uses signature-based detection mainly and it is the quickest scan that the user can use.
- However, quick scan fails when malware is more hidden in uncommon areas and is usually hidden within legitimate software process.
- The second scan mode is Full Scan
- Full Scan is where OSGuardian scans through all processes, protected folders and all other folders & files on the device.
- Full scan is mainly effective when malware-level threats are hiding within legitimate processes that are within the operating system environment.
- However, full scan fails when malware is hidden within a legitimate operating system and software process or it is fileless malware.
- This consumes more resources but ensures that malware isn't hiding in places the quick scan may miss.
- The third scan mode is custom scan
- Custom Scan is where OSGuardian allows the user to scan a specific process, file or folder on the device within the operating system environment.
- Custom scan is mainly effective when the user is suspicious or wants to verify a process on their device which means that users can detect malware from downloaded cracked or malicious software.
- However, custom scan fails if the user isn't suspicious or isn't trained to know malware patterns on a device meaning that malware can slip through.
- This scans through a user-specified file, folder or process for malware
- This allows users to check if a process or file is safe before interacting with it.
- The fourth scan mode is offline scan
- Offline Scan is where OSGuardian boots before the OS is loaded and scans BIOS/UEFI, boot sectors, drivers and kernel-level processes for malware.
- Offline scan is mainly effective against rootkits, bootkits and other nation-state level malware as it scans outside of the operating system environment removing any threats.
- However, Offline Scan fails when malware is rooted deep into the legitimate boot level processes or if these sectors of the device have already been damaged.
- These scan modes cover 90% of user-specific cases giving the user control while the 4 detection layers OSGuardian handles real-time and automated protection.
- It is important to remember that offline scan and full scan can take the longest due to scanning large amounts of data on the device for malware.

## **Ransomware-Specific Protections**

- There are a few ransomware-specific protections that OSGuardian uses.
- The first protection is behavioural detection.
- Behavioural detection is where OSGuardian monitors encryption patterns in real-time to detect ransomware activity
- Behavioural detection is mainly effective against known ransomware threats that use bulk or anomalous encryption patterns which is commonly used by script kiddies or opportunistic attackers.
- For example, a common ransomware pattern could be encrypting 200+ files per second.
- However, Behavioural detection fails when ransomware hides as legitimate encryption software and maintains normal encryption behaviour.
- The second protection is ML detection
- ML detection is where OSGuardian uses its ML learning detection layer to cross-reference known ransomware-patterns against user-specific encryption patterns.
- This also learns what legitimate encryption tools that the user uses to reduce the number of false positives.
- This is mainly effective against ransomware hiding as legitimate processes or maintain normal encryption patterns as ransomware cannot act like a human.
- However, ML detection fails when the ransomware maintains user-specific behaviour and tools.
- The third protection is controlled access.
- Controlled access is where OSGuardian monitors encryption changes to user-defined folders for ransomware attempts.
- For example, a user may define their documents, videos and images to be protected from ransomware.
- Controlled access is mainly effective against known ransomware patterns as it is reactive based on encryption changes and activity within the protected folders.
- However, Controlled access fails when ransomware uses legitimate encryption process and legitimate behaviour however this is unlikely to be successful.
- The fourth protection is recovery.
- Recovery is where OSGuardian uses 7 OS snapshots to recover the operating system back to a clean state after the ransomware is removed with minimal data loss.
- OSGuardian will also generate verification hashes and later use them to verify that the snapshots haven't been tampered with by malware.
- OSGuardian will also ask the user for their admin password to use the snapshots to prevent recovery-based attacks.
- Recovery is mainly effective for restoring data after a ransomware attack and serves as a quick and more efficient process compared to using USBs.
- However, Recovery fails when the snapshots are already infected by malware which is unlikely but not impossible.

## **OSGuardian User Control, Privacy and Phishing Protections**

- **OSGuardian also respects privacy and user control over the device.**
- **OSGuardian is built with a local-first model.**
- **This means that all data and learning is done locally on the user's device with the only exception being global threat data that comes and is updated by the provider.**
- **Users can also delete, export or import their OSGuardian ML data although deletion is not recommended for security reasons.**
- **It is important to remember that ML profile is specific to the user's device so it can protect them specifically instead of generic cloud data.**
- **OSGuardian only sends threat data such as malware signatures or malware patterns back to the cloud so everyone can be updated with the latest protection.**
- **This feature provides the best possible balance between privacy and security for OSGuardian's ML detection layer**
- **OSGuardian will also have some phishing protections to help users protect themselves against it.**
- **OSGuardian alerts will be human-centric language which never makes the user scared or panic during malware level threats or scans.**
- **The OSGuardian alerts will never lead to external websites with the exception to online documentation. These alerts will lead to OSGuardian's dashboard.**
- **Users are also alerted that OSGuardian can have false positives especially with ransomware, but these false positives will reduce over time.**
- **For example, an alert could look like "Quick scan completed. No threats were found on your device. You can check out OSGuardian's dashboard for more details."**
- **OSGuardian's dashboard will have 4 main and clear sections for protection.**
- **The first section is the main dashboard.**
- **OSGuardian's main dashboard will include a description of what OSGuardian is, provide scan modes options and allow changes to core settings like real-time protection.**
- **The second section is protection & update history.**
- **This should show all background security updates to ML training data and security intelligence updates for signature-based detection**
- **For protection history, it should show every blocked threat with information such as the process, the time, what action was taken.**
- **The third section is ML settings which will allow you to import, export and delete ML data from OSGuardian.**
- **The fourth section is ransomware protection.**
- **This section should include options such as protected folders, recovery-policy for snapshots and legitimate encryption tools whitelisting.**

## **OSGuardian's Workflow**

- **First, the user turns on their device and boots up the operating system for the first time.**
- **After the operating system has been loaded, OSGuardian creates the first OS snapshot and verification hash.**
- **Third, the user uses their device for work and personal activities using software like Microsoft word or Google docs on their web browser.**
- **One day, the user falls for a phishing email downloading a malicious document onto their device.**
- **OSGuardian's signature-based detection immediately recognises the malware signature.**
- **OSGuardian immediately quarantines and removes the threat from the device and alerts the user with a human-centric message.**
- **The user sees "OSGuardian detected and removed a threat from your device. You do not need to take any action. Look at OSGuardian's dashboard for more information"**
- **The user continues working and doing personal activities on their device.**
- **5 months, an attacker manages to exploit a vulnerability in SMB to deliver ransomware to the user's device.**
- **The ransomware immediately begins to encrypt files on the device however OSGuardian detects the ransomware using 3 layers**
- **OSGuardian's real-time behavioural detection sees the ransomware encryption pattern of encrypting 100s of files per second.**
- **OSGuardian's ML detection cross-references user-specific encryption against the ransomware encryption and detects the difference**
- **OSGuardian detects an unauthorised change attempt to folders within the protected folder list and immediately ends the ransomware process.**
- **After ransomware is confirmed, OSGuardian immediately stops the ransomware process, removes the ransomware and prompts the user into recovery mode.**
- **The user sees "OSGuardian detected and removed a threat from your device. You must enter recovery mode to restore clean state. You may experience minimal data loss."**
- **The user enters their admin or account password and enters recovery option where they are given the opportunity to restore from one of the 7 snapshots.**
- **Once the user chooses a snapshot, OSGuardian verifies the snapshot via the verification hash.**
- **The snapshot is used to restore the operating system, and the user can proceed with their work with minimal data loss.**

## **OSGuardian's Update System and ML Handling**

- It is important that OSGuardian and its detection layers stay updated with the latest threat data.
- There are two areas that OSGuardian's update system targets.
- The first area is the ML's model data.
- The ML's model data would be stored encrypted on the device, and the model would confirm its data hasn't been tampered with using a verification hash.
- If the model's data has been tampered with the ML can request a new copy of threat data from cloud servers and begin learning user-specific data once again.
- The ML's training data should only include malware threats, malware patterns and suspicious activity on a system to be efficient and effective.
- These malware threats should be both legacy and involve the current newest threats in cybersecurity.
- For the example, the most dangerous malware threats include Ransomware, Spyware, Trojans, Rootkits/boot kits, fileless malware, RATs, and nation-state malware.
- The ML model also requires updated threat data to detect known malware behaviour patterns against user-specific patterns.
- The second area is security intelligence updates
- OSGuardian's signature-database would need to be updated constantly with the latest malware signatures.
- This signature-database can be stored locally on the device encrypted and verified via a verification hash by OSGuardian to prevent the usage of fake signatures.
- The provider can roll out security intelligence updates that add to the local signature database allowing for OSGuardian to detect the latest threats.
- OSGuardian updates would be verified through a cryptographic key used by the provider to ensure that updates aren't malicious before they are installed.
- This update system provides tamper-proofing at every level, privacy respecting and efficient updates to OSGuardian.



## **OSGuardian's Trade-offs**

- **OSGuardian has trade-offs just like any other system I have built so far.**
- **There are 3 trade-offs I have identified for OSGuardian.**
- **There may also be further implementation challenges that developers may face.**
- **The first trade-off is Performance Impact.**
- **This trade-off exists because OSGuardian uses multiple real-time methods to detect and respond to malware.**
- **This means that OSGuardian can be quite computationally intensive as it is constantly learning, adapting and responding to threats in real time**
- **This trade-off can be managed through my RAM Memory Architecture and the local-model, user-start, privacy first sections of OSGuardian.**
- **The second trade-off is False Positives.**
- **This trade-off exists because OSGuardian may detect legitimate processes or tools as malware as it may have similar behavioural patterns.**
- **However, this trade-off can be managed as the ML model learns and helps reduce false positives and the user can allow specific programs or processes through.**
- **The third trade-off is Updates Required.**
- **This trade-off exists because OSGuardian constantly requires security intelligence and ML training data updates.**
- **This trade-off can be managed through update schedules, update teams, and updating the ML training data when new threats arrive and not small incremental updates.**